Report Tecnico – Penetration Testing

1. Obiettivo

L'obiettivo dell'attività è stato analizzare una macchina target attraverso tecniche di enumerazione e penetration testing, individuando eventuali vulnerabilità e configurazioni errate che potessero consentire di ottenere accesso al sistema e successivamente aumentare i propri privilegi.

L'attività è stata svolta seguendo un approccio progressivo: identificazione dei servizi esposti, ricerca di informazioni, enumerazione SMB, accesso tramite SSH e privilege escalation fino all'utente finale.

---

2. Scansione iniziale con Nmap

Come primo passaggio ho eseguito una scansione con Nmap per individuare le porte aperte, i servizi attivi e le relative versioni.

La scansione ha restituito i seguenti risultati:

Porta	Servizio	Versione
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu
80/tcp	HTTP	Apache httpd 2.4.41
139/tcp	NetBIOS-SSN	Samba smbd 4
445/tcp	SMB	Samba smbd 4
8009/tcp	AJP13	Apache Jserv Protocol v1.3
8080/tcp	HTTP	Apache Tomcat 9.0.7

La presenza di diversi servizi web, insieme alle porte SMB e SSH, ha offerto diverse possibilità di enumerazione.

Ho deciso di iniziare analizzando il servizio HTTP sulla porta 80.

---

3. Enumerazione delle directory HTTP

Per individuare eventuali directory non direttamente visibili dal sito web, ho utilizzato Gobuster con la wordlist `common-2.3-small`.

Durante la scansione è stata individuata una directory interessante:

`/development`

Accedendo alla directory ho trovato due file di testo:

- `dev.txt`
- `j.txt`

Analisi di dev.txt

Il primo file conteneva alcune informazioni relative alla configurazione e allo sviluppo del server.

In particolare, una nota del 23 aprile 2018 menzionava l'utilizzo di Apache Struts nella versione 2.5.12.

Erano inoltre presenti riferimenti alla configurazione di SMB e all'installazione di Apache.

Questa informazione rappresentava un possibile punto di approfondimento, soprattutto considerando la presenza di diversi servizi web.

Analisi di j.txt

Il secondo file conteneva un messaggio rivolto a un utente chiamato Jan.

Dal contenuto emergeva che un amministratore aveva verificato gli hash presenti in `/etc/shadow`, riuscendo a decifrare facilmente la password di Jan.

Il messaggio suggeriva quindi la presenza di credenziali deboli o di una password non conforme alle policy di sicurezza.

Ho ipotizzato che la password potesse non essere ancora stata modificata e ho deciso di verificare questa possibilità.

---

4. Primo tentativo di accesso: SSH

Sfruttando le informazioni raccolte, ho provato a individuare le credenziali di accesso tramite un attacco brute force.

Il tentativo iniziale non ha prodotto risultati.

Ho quindi deciso di cambiare approccio, concentrandomi sul servizio SMB, esposto sulle porte 139 e 445.

---

5. Enumerazione SMB

Per verificare quali condivisioni fossero accessibili senza autenticazione, ho utilizzato il comando:

smbclient -L //10.128.187.110/Anonymous -N

L'enumerazione ha permesso di individuare una condivisione chiamata `Anonymous`.

Ho quindi effettuato l'accesso utilizzando:

smbclient //10.128.187.110/Anonymous -N

Una volta entrato nella condivisione, ho eseguito `ls` e individuato il file:

`staff.txt`

Ho scaricato il file utilizzando il comando `get` e ne ho analizzato il contenuto.

Informazioni ricavate

Il file conteneva un messaggio rivolto allo staff che menzionava esplicitamente due utenti:

- **Kay**
- **Jan**

A questo punto disponevo di un nome utente concreto da utilizzare per un nuovo tentativo di autenticazione SSH.

---

6. Accesso SSH come Jan

Avendo individuato il nome utente Jan e avendo già raccolto indizi sulla possibile debolezza della sua password, ho deciso di riprovare con Hydra.

Ho utilizzato il seguente comando:

hydra -l jan -P /usr/share/wordlists/rockyou.txt -t 4 -f -V ssh://10.128.187.110

Dopo circa 780 tentativi, Hydra ha individuato una password valida:

armando

Sono quindi riuscito ad autenticarmi tramite SSH come utente `jan`.

L'accesso iniziale non ha però permesso di raggiungere direttamente l'obiettivo, rendendo necessario approfondire la configurazione e i permessi del sistema.

---

7. Enumerazione locale e ricerca di informazioni

Una volta ottenuto l'accesso come Jan, ho deciso di utilizzare LinEnum per effettuare un'analisi dell'ambiente Linux.

Ho trasferito lo script sulla macchina target tramite SCP, così da poterlo eseguire direttamente sul sistema.

Durante l'esplorazione ho individuato una configurazione particolarmente interessante: alcuni file e directory appartenenti all'utente Kay presentavano permessi di lettura eccessivamente permissivi.

In particolare, sono riuscito ad accedere in lettura ai contenuti della directory:

`/home/kay/.ssh`

All'interno ho individuato la chiave privata SSH `id_rsa`.

Questa scoperta ha rappresentato il punto di svolta dell'attività: Kay utilizzava un'autenticazione basata su chiavi SSH e la relativa chiave privata era leggibile da un altro utente locale.

---

8. Recupero della passphrase della chiave SSH

Ho copiato la chiave privata sul mio computer e ho utilizzato `ssh2john` per convertirla in un formato compatibile con John the Ripper.

Comando utilizzato:

ssh2john id_rsa > kay_hash.txt

Successivamente ho avviato John utilizzando la wordlist RockYou:

john --wordlist=/usr/share/wordlists/rockyou.txt kay_hash.txt

L'operazione è andata a buon fine e ho recuperato la passphrase della chiave privata:

beeswax

A questo punto avevo tutti gli elementi necessari per autenticarmi come Kay.

---

9. Accesso SSH come Kay

Utilizzando la chiave privata e la passphrase appena recuperata, ho effettuato una nuova connessione SSH:

ssh -i id_rsa kay@IP_MACCHINA

L'autenticazione è riuscita e ho ottenuto una sessione SSH con l'utente `kay`.

Ho quindi verificato i file presenti nella sua home directory e individuato il file:

`/home/kay/pass.bak`

Il file conteneva la password finale:

heresareallystrongpasswordthatfollowsthepasswordpolicy$$

La lettura di questo file ha concluso con successo l'attività.

---

10. Vulnerabilità e configurazioni errate individuate

Durante l'attività sono emerse diverse problematiche di sicurezza:

Vulnerabilità / Misconfiguration	Impatto
Directory web esposta (`/development`)	Divulgazione di informazioni interne
Condivisione SMB accessibile senza autenticazione	Accesso non autorizzato a file interni
Password debole dell'utente Jan	Possibilità di compromissione tramite brute force
Permessi eccessivamente permissivi su `.ssh`	Esposizione della chiave privata di Kay
Passphrase debole della chiave SSH	Possibilità di recupero tramite cracking offline
File `pass.bak` leggibile da Kay	Esposizione di una password memorizzata in chiaro

---

11. Conclusioni

L'attività ha dimostrato come una combinazione di configurazioni errate e credenziali deboli possa compromettere progressivamente la sicurezza di un sistema Linux.

Il punto più importante non è stato un singolo exploit, ma la capacità di collegare le informazioni raccolte durante le diverse fasi dell'enumerazione.

Partendo da una semplice scansione Nmap, sono riuscito a individuare una directory web contenente informazioni utili, sfruttare una condivisione SMB accessibile anonimamente, ottenere le credenziali di Jan e infine sfruttare permessi eccessivamente permissivi per recuperare la chiave SSH di Kay.

Il recupero della passphrase ha permesso di autenticarmi come Kay e leggere il file finale `pass.bak`, completando così la macchina.

Attività completata con successo.